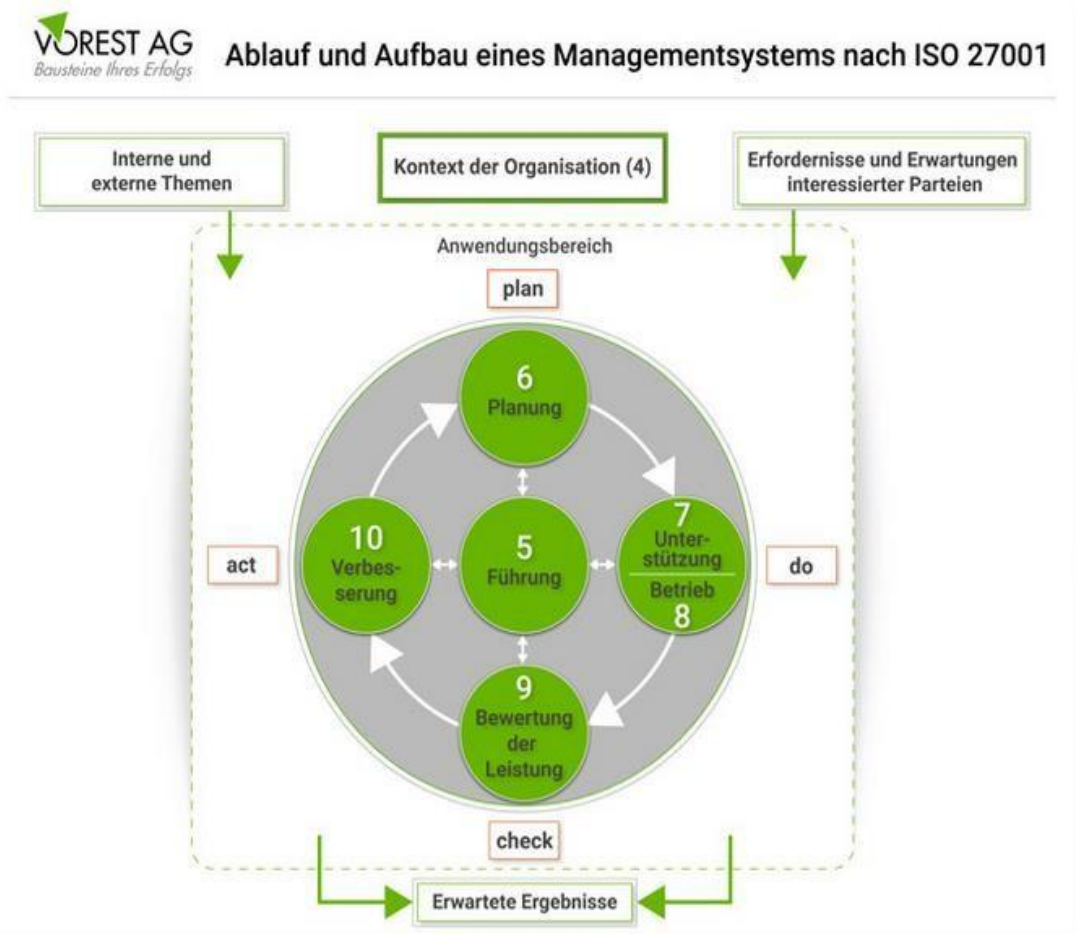
Spezifikation und Anforderungen

SuA der ISO/IEC27001

Norm | Struktur und Inhalte der ISO/IEC 27001



1. Anwendungsbereich
2. Normative Verweisungen
3. Begriffe
4. Kontext der Organisation
5. Führung
6. Planung
7. Unterstützung
8. Betrieb
9. Bewertung der Leistung
10. Verbesserung

Norm | Abschnitt 4 | Kontext der Organisation

- Abschnitt 4 der ISO 27001 stellt Anforderungen an den Kontext einer Organisation und ist in folgende Teilabschnitte gegliedert
  - Verstehen der Organisation und des Kontextes
  - Verstehen der Erfordernisse und Erwartungen interessierter Parteien
  - Festlegen des Anwendungsbereiches (Scope) eines ISMS
  - Das ISMS

Norm | Abschnitt 4 | Kontext der Organisation | 4.1 Verstehen der Organisation und des Kontextes

- ISO 27001 macht keine Vorgaben darüber, welche internen und externen Themen Sie beobachten und analysieren müssen.

- Es ist eine Frage der **Relevanz**. Im Kern ist es aber ganz einfach.

  Sie müssen klären, welche potenziellen Bedrohungen existieren, welche Vorgaben Sie beachten müssen und welche Bereiche Ihrer Organisation davon betroffen sind.

Norm | Abschnitt 4 | Kontext der Organisation | 4.2 Verstehen der Erfordernisse und Erwartungen interessierter Parteien

- Die Organisation muss die **Parteien** und deren **Anforderungen** in Bezug auf die **Informationssicherheit bestimmen**

Norm | Abschnitt 4 | Kontext der Organisation | 4.3. Festlegen des Anwendungsbereichs [Scope]

- Entgegen einer weit verbreiteten Annahme muss ISO 27001 nicht automatisch für eine gesamte Organisation implementiert werden.
- Es ist sogar **denkbar**, dass Sie ISO/IEC27001 nur für **wenige Prozesse umsetzen**, beispielsweise für alle Abläufe und Tätigkeiten rund um den Einsatz eines CRM-Systems (Customer Relationship Managementsystem).
- Deshalb ist es erforderlich, den **Anwendungsbereich (Scope)** der ISO/IEC 27001 klar zu definieren.

Norm | Abschnitt 4 | Kontext der Organisation

- Übungsbeispiel:
  - Recherchiere im Internet nach gültigen ISO/IEC 27001 Zertifikaten. Untersuche dabei die Scopedefinition (Anwendungsbereich) dieser Unternehmen. Versuche auch einen Zusammenhang zu den betreffenden Branchen herzustellen.
  - Dokumentiere die Ergebnisse:
    - Links
    - Anmerkungen
    - Zusammenhänge mit Branchen

Norm | Abschnitt 4 | Kontext der Organisation

- Finde im Bericht die Antworten für die nachfolgenden Fragen:
  https://reports.weforum.org/docs/WEF_Global_Cybersecurity_Outlook_2025.pdf

- Was wird die Cybersecurity im Jahr 2025 maßgeblich beeinflussen?
- Welche Cyberbedrohungen werden Unternehmen am meisten betreffen?
- Welche kritische Infrastruktur ist besonders Schützenswert?

Norm | Abschnitt 5 | Führung

- Der Organisationsleitung wird damit zum einen die **Verantwortung** für viele der Aktivitäten zugeteilt, die im übrigen Normentext mit der Formulierung „Die Organisation **muss** . . . “ eingeleitet werden.

- Durch die **Verpflichtung**, dass die **oberste Leitung** die erfolgreiche Umsetzung dieser Aktivitäten sicherstellt, wird verdeutlicht, dass der Aufbau und Betrieb eines ISMS kein Vorhaben ist, das an eine einzelne Fachabteilung oder eine Person wie den IT-Leiter delegiert werden kann.

Norm | Abschnitt 5 | Führung | Aufgaben

- Tragende Rolle im Bereich der **Kommunikation**: Sie muss die **Relevanz** von Informationssicherheitsmanagement **aktiv kommunizieren** und alle beteiligten Personen in die Lage versetzen, zur Wirksamkeit des ISMS beizutragen.

- Auf die **kontinuierliche Verbesserung** (P-D-C-A) hinwirken und darf sich somit nach der Initiierung von Aktivitäten zur Planung und zum Aufbau eines ISMS nicht zurückziehen, um alle weiteren Aufgaben beispielsweise dem technischen Personal zu überlassen.

Norm | Abschnitt 5 | Führung | Rollen, Verantwortlichkeiten und Befugnisse in der Organisation

- Aufgabe der Organisationsleitung ist, das **Festlegen von Rollen, Verantwortlichkeiten und Befugnissen** sicherzustellen.

- Mit dieser Regelung wird neben der **unmittelbaren Auswirkung**, dass **Zuständigkeiten** und damit einhergehende **Befugnisse festgelegt** werden, auch die Grundlage dafür geschaffen, organisationsinterne ISMS-Audits durchzuführen, die ein wesentlicher Baustein für die **kontinuierliche Verbesserung** des ISMS sind.

Norm | Abschnitt 5 | Führung | Aktive Engagement

- Führung bedeutet aktives Engagement des Top Managements, wobei alle genannten Punkte zwingend erfüllt, und daher nachgewiesen werden müssen.
  - **IS-Leitlinie**
    Nur die Führung kann **Ziele** vorgeben und falls nötig, **Organisationsprozesse** dazu anpassen
  - **Ressourcen**
    Nicht nur **Geld** für Maßnahmen muss bereit gestellt werden, sondern auch **genügend Zeit** für die Mitarbeiter, das ISMS **aufzubauen** und zu **betreuen**.
  - **Kommunikation**
    Die **Mitwirkung** aller **Mitarbeiter** ist für ein funktionierendes ISMS **essentiell**. Kommunikation der Bedeutung dieses ISMS für die eigene Organisation kann effizient nur von der Führung durchgeführt werden
  - **Führung und Unterstützung**
    Sowohl **organisatorische** als auch **persönliche Widerstände** müssen durch Zuspruch und Unterstützung anderer Manager beseitigt werden.

Norm | Abschnitt 5 | Führung |Leitlinien

- Eine Reihe von **Leitlinien zur Informationssicherheit** sollte **definiert** werden, vom Management **genehmigt**, bekannt gegeben und Mitarbeitern sowie relevanten externen Stellen mitgeteilt werden. Die Leitlinien müssen für alle relevanten Parteien **zugänglich** sein. (=> Intranet)

- Leitlinien berücksichtigen die **Unternehmensstrategie, Vorschriften, Gesetze** und **Verträge** sowie das **Bedrohungsumfeld**.

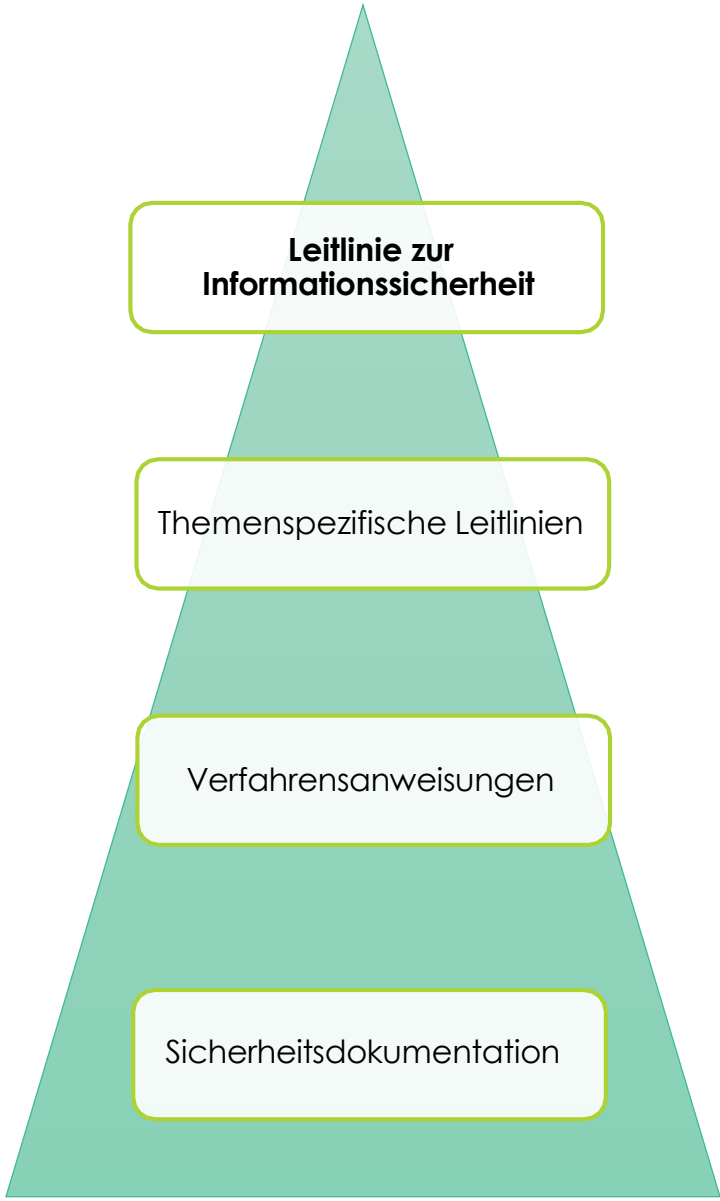
Norm | Abschnitt 5 | Führung | Leitlinien zur Informationssicherheit

- Leitlinie zur Informationssicherheit
  Beispiel

- Leitlinien zur Telearbeit
- Leitlinien zur Zugriffskontrolle

- Verfahren für interne Audits
- Verfahren zum Vorfallmanagement

- Produktspezifische Einstellungen
- Backup Plan

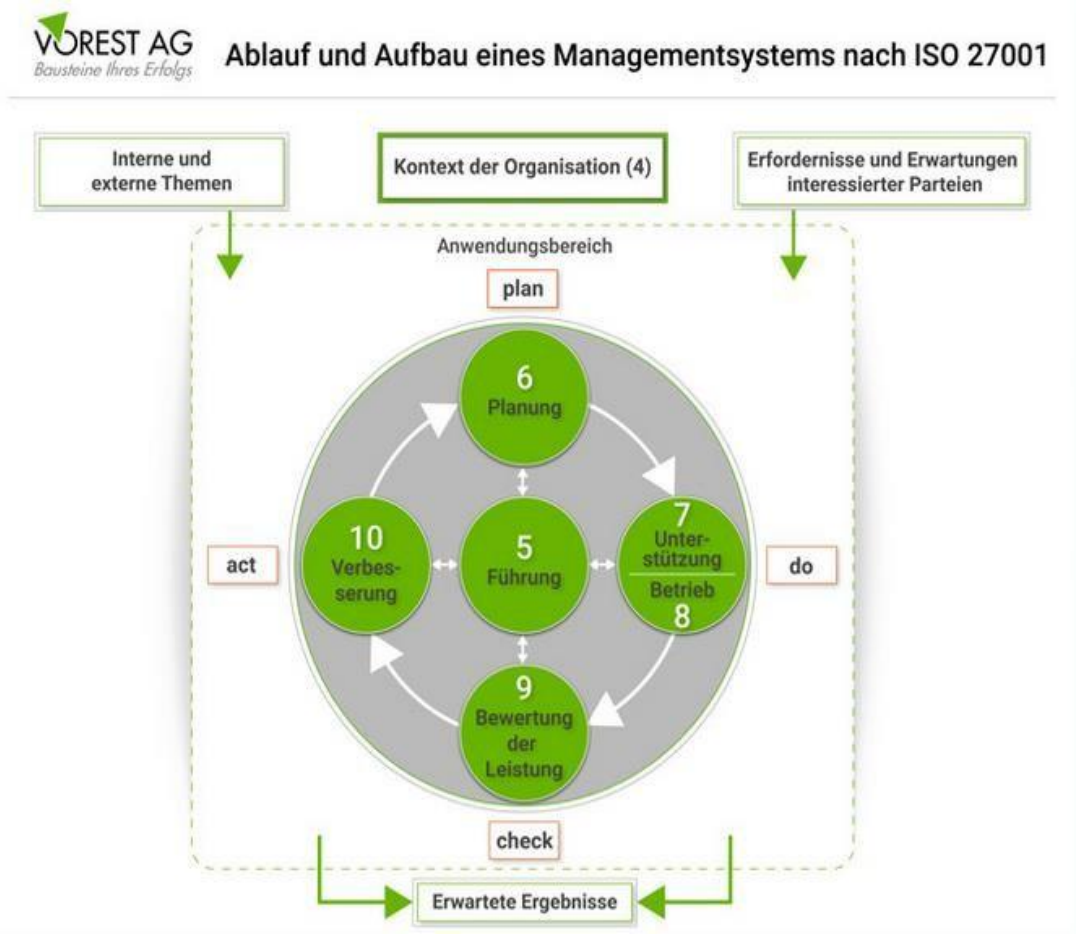


Norm | Abschnitt 5 | Führung | Normative Voraussetzungen

Aus der Norm:

- 5.1 Führung und Verpflichtung
  - die Festlegung einer Strategie zur Informationssicherheit,
  - die Integration des ISMS in Geschäftsprozesse,
  - die Zurverfügungstellung der erforderlichen Ressourcen,
  - die Messung der Wirksamkeit und kontinuierlichen Verbesserung des ISMS und
  - die Sensibilisierung der Mitarbeiter auf allen Ebenen?
- 5.2 Politik
  - Hat die Geschäftsführung eine Leitlinie zur Informationssicherheit verabschiedet und bekannt gemacht?
- 5.3 Rollen, Verantwortlichkeiten und Befugnisse in der Organisation
  - Hat die Geschäftsführung Rollen, Verantwortlichkeiten und Befugnisse im Rahmen des ISMS benannt und erhält Berichte von diesen?

Norm | Abschnitt 6 | Planung |



1. Anwendungsbereich
2. Normative Verweisungen
3. Begriffe
4. Kontext der Organisation
5. Führung
6. Planung
7. Unterstützung
8. Betrieb
9. Bewertung der Leistung
10. Verbesserung

Norm | Abschnitt 6 | Planung

- Nachdem im Rahmen der **Informationssicherheitspolitik** übergeordnete **Richtlinien** für das Management der Informationssicherheit festgelegt und wesentliche **Rollen** und Verantwortlichkeiten definiert und zugewiesen wurden, können konkretere Schritte der Planung im Zusammenhang mit dem ISMS eingeleitet werden. Abschnitt 6 der Norm adressiert diesen Aspekt – sozusagen die erste Plan-Phase im Sinne des PDCA-Kreislaufs bei der

- **Einführung eines ISMS – und betrachtet hierzu zwei Themen**:
  - Maßnahmen zum Umgang mit Risiken und Chancen
  - Informationssicherheitsziele und Planung zu deren Erreichung

Norm | Abschnitt 6 | Planung | 6.1 Maßnahmen zum Umgang mit Risiken und Chancen

- Die **Erfordernisse und Erwartungen** interessierter Parteien sowie der Kontext der Organisation, wie zuvor identifiziert, müssen beim Aufbau des ISMS **berücksichtigt** werden.
- Dieser Teil der Planung des ISMS setzt sich allgemein mit Risiken und Chancen auseinander, die mit der Etablierung des Managementsystems verbunden sein können.

Norm | Abschnitt 6 | Planung | 6.1 Maßnahmen zum Umgang mit Risiken und Chancen

- Typische Beispiele für Chancen, die mit einem ISMS verbunden sein können, sind:
  - **Professioneller und systematischer Umgang** mit allen Aspekten der Informationssicherheit durch Anwendung der **Prozesse und Methoden**, die das Managementsystem bereitstellt.
  - Möglichkeit der **Nachweisführung** über ein professionelles Informationssicherheitsmanagement über Audits und Zertifizierungen – etwa auch gegenüber interessierten Parteien.
  - Erhöhung des **erreichbaren Niveaus** der Informationssicherheit durch **funktionierende Prozesse** zur **Risikobeurteilung und -behandlung** (siehe Abschnitte 6.1.2 und 6.1.3 der Norm), Ableitung zielgerichteter Maßnahmen zur effektiven Risikobehandlung und Anwendung von Referenz- Maßnahmen.
  - **Erhöhung der Effizienz bzw. Wirtschaftlichkeit** im Umgang mit Informationssicherheit, indem durch Kontrollmechanismen wie die Auswertung von Leistungskennzahlen mögliche Ineffizienzen aufgedeckt werden können.

Norm | Abschnitt 6 | Planung | 6.1 Maßnahmen zum Umgang mit Risiken und Chancen

- Trotz aller **potenzieller Chancen**, die die Einführung eines ISMS einer Organisation eröffnen kann, sollte man nicht ausblenden, dass Managementsysteme und ihre Etablierung **auch Risiken** mit sich bringen können.
- Häufig stehen diese im direkten oder indirekten Zusammenhang mit den organisatorischen oder kulturellen Veränderungen, die ein Managementsystem erfordert.
  Hier einige Beispiele:
  - **Verlangsamung** von Abläufen durch **übermäßige Bürokratie** und damit verbundene Aufwände.
  - **Verringerung der Motivation und Leistungsbereitschaft** von Personen, die Rollen im Rahmen des ISMS übernehmen, wenn durch die Einführung des ISMS überwiegend **nachteilige Auswirkungen** auf das persönliche Arbeitsumfeld wahrgenommen werden.

Norm | Abschnitt 6 | Planung | 6.1 Maßnahmen zum Umgang mit Risiken und Chancen

- Eine ganz wesentliche Säule des ISMS ist ein funktionierendes **Risikomanagement**. Dabei lassen sich die Phasen der **Risikobeurteilung** und der **Risikobehandlung** unterscheiden.
- Die Norm adressiert das Risikomanagement gleich an zwei Stellen:
  - Als Teil der **Planung des ISMS** (Abschnitte 6.1.2 und 6.1.3, hier behandelt): **Informationssicherheitsrisiken** müssen bereits während der Phase der Planung und des Aufbaus des ISMS beurteilt werden, damit in Abhängigkeit von der ermittelten Risikoexposition fundierte Entscheidungen hinsichtlich der Ausgestaltung des ISMS getroffen werden.
  - Als Teil des **Betriebs des ISMS** (Abschnitte 8.2 und 8.3, in den Kapiteln 4.8.2 und 4.8.3 behandelt): Auch im laufenden Betrieb müssen **Risiken und die Maßnahmen**, die zu ihrer Behandlung ergriffen wurden, in **regelmäßigen** Abständen **erneut** bewertet bzw. nachverfolgt werden.

Norm | Abschnitt 6 | Planung | 6.1.2 Informationssicherheitsrisikobeurteilung

- Die Risikobeurteilung ist ein Prozess, der **potentielle Bedrohungen identifiziert und bewertet.**

- Die **Kriterien zur Risikoakzeptanz** legen die Bedingungen fest, unter denen identifizierte Risiken grundsätzlich bewusst akzeptiert werden dürfen.
  - Beispiel: Die Kosten / Aufwände der wirtschaftlichsten Risikobehandlungsmöglichkeit über einen definierten Zeitraum sind größer als der zu erwartende Schaden durch das Risiko in diesem Zeitraum (Schadenshöhe unter Berücksichtigung der Eintrittswahrscheinlichkeit).
- Aus der **Beurteilung** erfolgt eine Definition vom **Risikoniveau**
  - zum Beispiel:
    - unbedeutendes Risiko,
    - minderes Risiko,
    - signifikantes Risiko,
    - erhebliches Risiko,
    - kritisches Risiko

Norm | Abschnitt 6 | Planung | 6.1.2 Informationssicherheitsrisikobeurteilung

- typischen **Aktivitäten** in der Phase der **Risikobeurteilung**
  1. **Risiko identifizieren**: Ein Risiko wird **erkannt** und **beschrieben**. Hierzu werden häufig Schwachstellen und Bedrohungen im Kontext von Vermögenswerten miteinander in Beziehung gesetzt.
  2. **Risiko analysieren**: Zum identifizierten Risiko werden eine **realistische Eintrittswahrscheinlichkeit** und **mögliche Auswirkungen** bei Risikoeintritt bestimmt. Dies kann in quantitativer oder qualitativer Weise erfolgen.
     - Quantitatives Risikoniveau = Eintrittswahrscheinlichkeit x Auswirkungswert. [% oder €]
     - Qualitatives Risikoniveau = [gering, mittel, hoch]
  3. **Risiko bewerten**: Es wird eine Priorität vergeben, um die **relative Wichtigkeit** der Risikobehandlung **im Vergleich** mit **weiteren** identifizierten **Risiken** anzugeben.

Norm | Abschnitt 6 | Planung | 6.1.3 Informationssicherheitsrisikobehandlung

- Risikobehandlung ist ein Prozess, um identifizierte Risiken zu verringern oder bewältigen.

- An dieser Stelle wird erstmals auf den **Anhang A** der Norm mit seinen 114 Referenz- Maßnahmen (Controls) zum Management der Informationssicherheit verwiesen.

- Die **Referenz-Maßnahmen** werden im **Kontext der Risikobehandlung** als eine Art **Checkliste** verwendet, mit der die Maßnahmen, die zur Behandlung der Risiken ergriffen werden, abgeglichen werden.
  Dies geschieht mit dem **Ziel**, möglichst **keine** essenziellen **Themen** bei der Risikobehandlung zu **vergessen**

Norm | Abschnitt 6 | Planung | Maßnahmen zum Umgang mit Risiken und Chancen

➢ **Bsp**:

A.12.1.4	Trennung von Entwicklungs-, Test- und Betriebsumgebungen	*Maßnahme* Entwicklungs-, Test- und Betriebsumgebungen sind voneinander getrennt, um das Risiko unbefugter Zugriffe auf oder Änderungen an der Betriebsumgebung zu verringern.

Norm | Abschnitt 6 | Planung | Maßnahmen zum Umgang mit Risiken und Chancen

- **Bsp**: A12.1.4 Trennung von Test- und Betriebsumgebungen
  - Option A: Es ist möglich, von jedem Rechner einer Betriebsumgebung Remote auf den Testrechner zuzugreifen.
  - Option B: Es gibt einen Rechner im Testnetz mit dem sich ein Rechner aus der Betriebsumgebung verbinden kann. Von dort kann dann remote auf alle anderen Rechner im Testsystem zugegriffen werden kann.
  - Abwägung und Entscheidung welche die bessere Option ist.

Norm | Abschnitt 6 | Planung | Maßnahmen zum Umgang mit Risiken und Chancen

- Die **wichtigsten Ergebnisse** der Phase der Risikobehandlung sind die **Erklärung zur Anwendbarkeit** (SOA) und der **Risikobehandlungsplan**.
- Bei der Erklärung zur Anwendbarkeit handelt es sich typischerweise um eine Liste der 114 Referenz-Maßnahmen aus dem Anhang A der Norm. Es ist definiert, welche Maßnahme umgesetzt wird und welche nicht umgesetzt wird. Bei **nicht Umsetzung** muss dies **begründet** werden.
- Ein **Ausschluss** kann gerechtfertigt werden, wenn **keine Assets oder Risiken identifiziert** wurden, auf die die Maßnahme passen würde.
  - In den meisten Fällen werden nur sehr wenige, gut begründete Ausschlüsse in der Anwendbarkeit von Maßnahmen durch die Zertifizierer akzeptiert.

Norm | Abschnitt 6 | Planung | Maßnahmen zum Umgang mit Risiken und Chancen

- Den **Risikobehandlungsplan** kann man sich am besten als eine zusammenfassende, **chronologische Darstellung** aller zur Risikobehandlung **eingeplanten Maßnahmen** vorstellen.

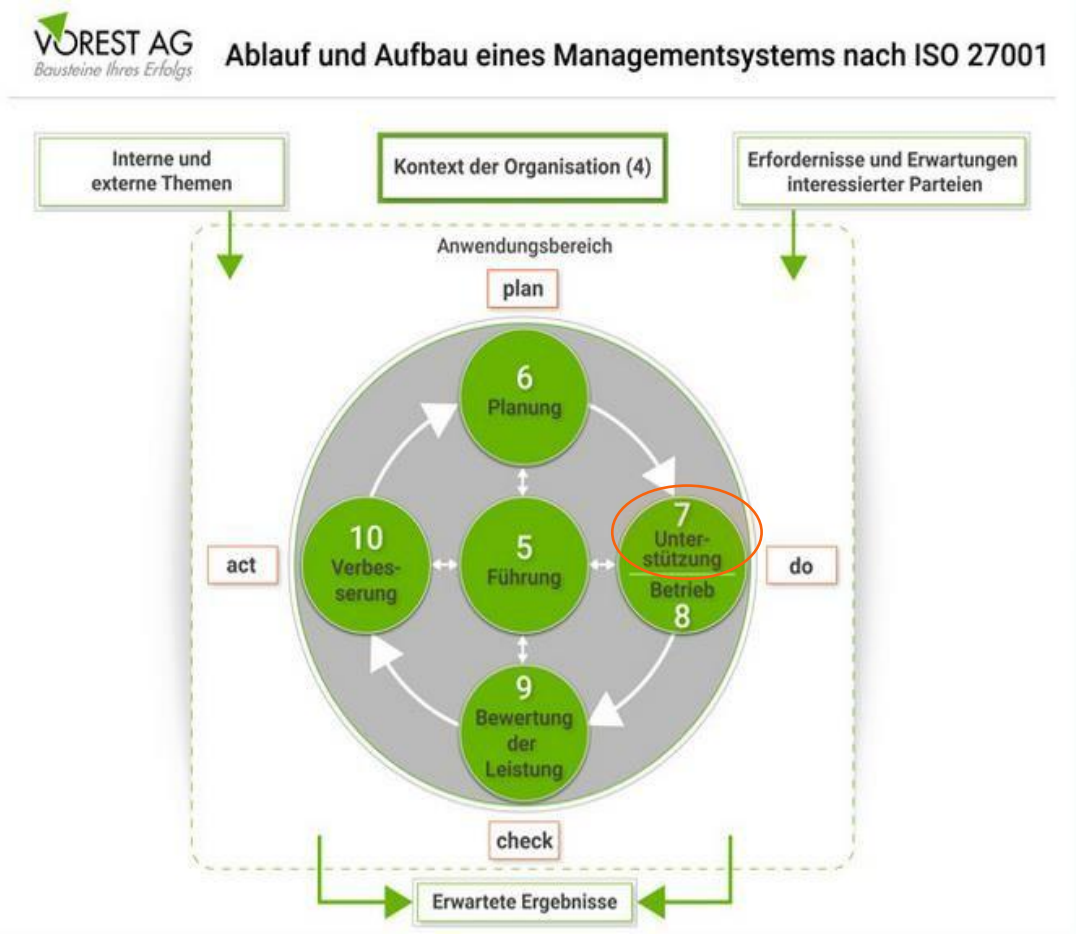
- Idealerweise referenziert er zu jeder Maßnahme auf das bzw. die zugeordneten Risiken. Er sollte neben dem vorgesehenen Termin für die Umsetzung jeder Maßnahme auch Informationen zum aktuellen Umsetzungsstatus und zu den Verantwortlichen darstellen.

- Die **verantwortlichen Risikoeigentümer** sollten ebenfalls daraus hervorgehen, wie auch **Akzeptanzentscheidungen** zu Risiken und Restrisiken.

Norm | Abschnitt 6 | Planung |
6.2 Informationssicherheitsziele und Planung zu deren Erreichung

- **Spezifische Ziele** sind häufig **Konkretisierungen**, die sich aus dem Kontext der Organisation oder auch aus identifizierten Schutzbedarfen und Risiken ergeben können.
- Für bestimmte **informationsverarbeitende Systeme** oder Dienste können Anforderungen an ihre Verfügbarkeit beispielsweise **quantitativ konkretisiert** werden – etwa durch Angabe eines **prozentualen Mindesterwartungswerts** oder einer **maximal tolerierbaren Zeitspanne** ungeplanter **Nichtverfügbarkeit**.

Norm | Abschnitt 7 | Unterstützung | Überblick



1. Anwendungsbereich
2. Normative Verweisungen
3. Begriffe
4. Kontext der Organisation
5. Führung
6. Planung
7. Unterstützung
8. Betrieb
9. Bewertung der Leistung
10. Verbesserung

Norm | Abschnitt 7 | Unterstützung | Überblick

- In der Norm wird Unterstützung als Voraussetzung für den Betrieb gesehen.
- Dieser Teil gliedert sich in 5 Teile
  1. Ressourcen
  2. Kompetenz
  3. Bewusstsein
  4. Kommunikation
  5. Dokumentierte Informationen

Norm | Abschnitt 7 | Unterstützung | 7.1 Ressourcen

- Die Organisation muss die erforderlichen Ressourcen bestimmen und bereitstellen.
- Dies gilt für
  - Den Aufbau
  - Die Verwirklichung
  - Die Aufrechterhaltung
  - Fortlaufende Verbesserung

Norm | Abschnitt 7 | Unterstützung | 7.2 Kompetenz

- Die Organisation muss, die für ISMS betrauten Personen auf ausreichende Kompetenz prüfen (Erfahrung, Schulung, Ausbildung).

- Zur Steigerung der Kompetenz müssen **Weiterbildungen oder Schulungen regelmäßig** durchgeführt werden. Mentoring kann durchaus ein geeignetes Mittel sein, um die Kompetenz zu verbessern.

- Nachweise über die Kompetenz müssen entsprechend aufbewahrt werden

Norm | Abschnitt 7 | Unterstützung | 7.3 Bewusstsein

- **Personen** in der Organisation sollen die Informationssicherheitspolitik kennen und ihre **relevanten Prozesse auch aktiv betreiben** können.
  Die **Dokumentation** dazu muss für Sie auch **selbstständig auffindbar** sein!

- Es müssen ihnen die **Vorteile** aufgrund eines ISMS **bekannt** sein und **wie** jede **einzelne Person** dazu **beiträgt**

- Außerdem müssen die Folgen bei Nichteinhaltung bewusst sein, sowohl für den einzelnen als auch für die Organisation.

Norm | Abschnitt 7 | Unterstützung | 7.3 Bewusstsein

- Mitarbeiter, die schon länger mit einem ISMS arbeiten, wissen oft nicht mehr die Vorteile und den Grund.
  → Regelmäßig mit Schulungen aufzeigen

- **Neue Mitarbeiter** müssen bereits von **Beginn an** damit **vertraut** gemacht werden. Oft **hinterfragen** sie einzelne Prozesse oder Dokumentationen. Dies sollte auf jeden Fall aufgenommen werden und im besten Fall zu einer Verbesserung/Überarbeitung führen.
  - Warum?
    - Erfahrung aus einem anderen Betrieb
    - Betriebsblind

Norm | Abschnitt 7 | Unterstützung | 7.4 Kommunikation

- **externe Kommunikation**
  - Jeder Person muss **klar** sein, **welche Informationen** weitergeleitet und **geteilt** werden dürfen.
  - Darüber hinaus muss bekannt sein, ob ein **Review und Freigabe notwendig** ist und wer dieses durchführt.

- **Beispiel**:
  Ein Bug bei der Authentifizierung ist intern schon länger bekannt aber noch nicht hoch priorisiert. Ein Kunde hat genau mit diesem Bug ein Problem gehabt. Ein Entwickler telefoniert mit dem Techniker vom Kunden und sagt folgendes: *„Ah der Bug ist schon lange drin. Da kann sich eigentlich jeder als Admin anmelden. Den fixen wir mal bei Gelegenheit.“*
  Wie ist wohl die Reaktion vom Kunden?

Norm | Abschnitt 7 | Unterstützung | 7.4 Kommunikation

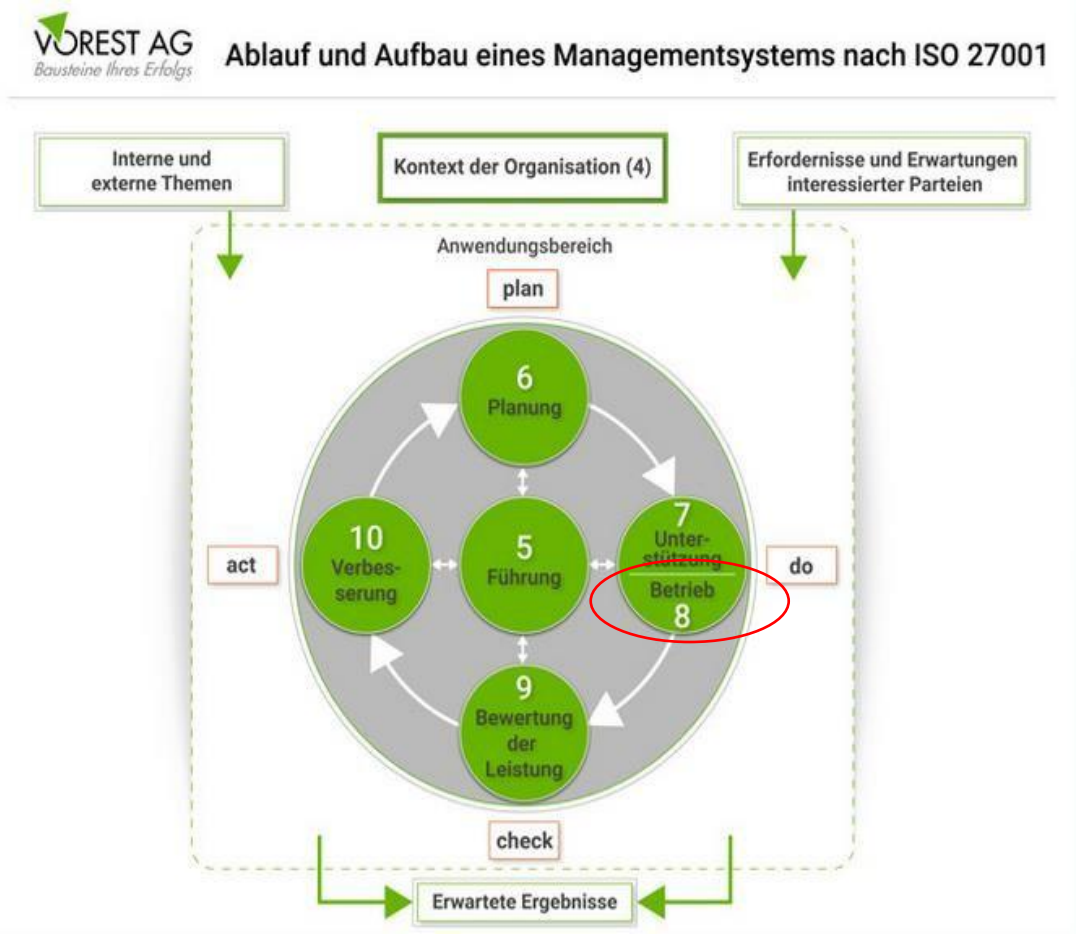
- **Interne Kommunikation**
  - Wenn ein Ernstfall eintritt, ist das wichtigste, dass jede Person weiß, an wem der Vorfall gemeldet werden muss.
- Dadurch kann weiterer Schaden bestmöglich vermieden werden.

- Beispiele:
  - Tür nicht versperrt → Haustechniker
  - In Phishing-Mail auf Link geklickt und Daten eingegeben → CISO, IT, Ticket für IS-Vorfälle
  - Laptop, Mobiltelefon gestohlen → IT, Ticket
  - Betriebsfremde Person fotografiert Pläne → ??

Norm | Abschnitt 7 | Unterstützung | 7.5 Dokumentierte Information

- Das ISMS und deren Unterlagen müssen dokumentiert sein
- Es muss eine angemessene Dokumentation vorhanden sein
  - Papier oder Elektronisch mit einem Tool
  - Kennzeichnung/Klassifizierung (intern, geheim,..)
  - Prüfung und Freigabe
- Gelenkt werden
  - Aufbewahrung
  - Verteilung an die Zielgruppen
  - Versionierung bei Änderungen

Norm | Abschnitt 8 | Betrieb



1. Anwendungsbereich
2. Normative Verweisungen
3. Begriffe
4. Kontext der Organisation
5. Führung
6. Planung
7. Unterstützung
8. Betrieb
9. Bewertung der Leistung
10. Verbesserung

Norm | Abschnitt 8 | Betrieb | 8.1 Betriebliche Planung und Steuerung

- Im Betrieb sind die geplanten Maßnahmen umzusetzen.
  - Budgets sind vorhanden
  - Einführung neuer Prozesse oder technischer Einrichtungen

- Bei Abweichungen (Budget, Zeit, Personal) muss entsprechend reagiert werden.
  - Betrachtung der Auswirkungen bei nicht Erfüllung
  - Der Risikobehandlungsplan kann unterstützend hinzugezogen werden → näheres im nächsten Punkt

- Dokumentation der Umsetzungsergebnisse

Norm | Abschnitt 8 | Betrieb | 8.2 Informationsrisikobeurteilung

- **Weicht** der **Plan während der Umsetzung** vom Ziel **ab**, müssen die Verantwortlichen **abwägen** und entscheiden, wie es weitergeht. Dadurch können sich durchaus Änderungen der Maßnahmen ergeben.

- **Beispiel**:
  Einführung eines digitalen Zutrittssystems (Maßnahme A11 Physische und umgebungsbezogene Sicherheit) in einer frühen Phase, in der auch die IT in ihren Services einiges erweitern muss.
  Ereignis: Lockdown Corona
  Abwägung ob die Maßnahmen „A6.2 Mobilgeräte und Telearbeit“ sowie Teile von „A13.1 Netzwerksicherheitsmanagement“ vorgezogen werden sollen.
  Die Ergebnisse müssen dokumentiert werden – z.B. im **Risikobehandlungsplan**

Norm | Abschnitt 8 | Betrieb | 8.3 Informationssicherheitsriskobehandlung

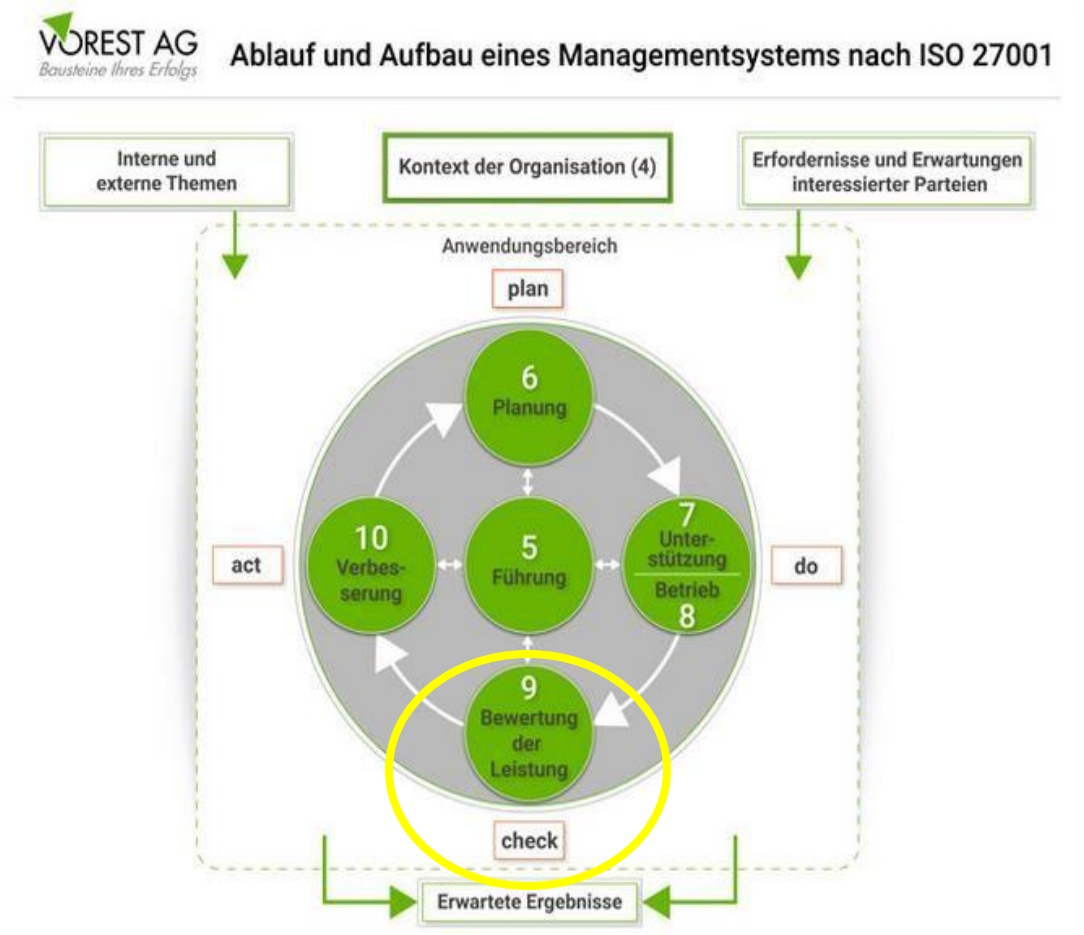
- Die Organisation muss den Risikobehandlungsplan regelmäßig kontrollieren und neu bewerten.
  - Bei Änderungen kann sich die Reihenfolge der Maßnahmen ändern

- Die Organisation muss den Plan für die IS-Risikobehandlung umsetzen.
  - Dies gilt für alle Maßnahmen, die in der SOA aufgenommen wurden.

- Die umgesetzten Maßnahmen sind ausreichend dokumentiert.

- Aus vorigem Bsp:
  Es wurde entschieden, das Zutrittssystem später Umzusetzen und das Budget, Personal, … für die Telearbeit früher umzusetzen

Norm | Abschnitt 9 |Bewertung der Leistung |



1. Anwendungsbereich
2. Normative Verweisungen
3. Begriffe
4. Kontext der Organisation
5. Führung
6. Planung
7. Unterstützung
8. Betrieb
9. Bewertung der Leistung
10. Verbesserung

Norm | Abschnitt 9 |Bewertung der Leistung | Überblick

- In diesem Abschnitt wird großteils **geprüft**, ob die umgesetzten **Maßnahmen** auf **sinnvoll, effizient** und **wirksam** sind.

- Um eine Leistung bewerten zu können muss diese
  - Überwacht, gemessen, analysiert und schließlich bewertet werden
  - Über interne Audits im Detail noch einmal genauer betrachtet werden
  - Dem Management die Ergebnisse vorgelegt werden, damit diese einen aktuellen Stand bekommt und weitere Maßnahmen setzen kann.

Norm | Abschnitt 9 |Bewertung der Leistung | 9.1 Überwachung, Messung, Analyse und Bewertung

- Überwachung: Daten sammeln
- Messung: Quantifizierung der gesammelten Daten
- Analyse: Interpretieren der Messung → Erkennen von Mustern
- Bewertung: Soll-Ist Vergleich

- Beispiel:
  - Überwachung eines geschützten Netzlaufwerks und Messung der fehlgeschlagenen Zugriffe
  - Überwachung der Sicherheitsvorfälle und Messung der Kosten
  - Überwachung der Sicherheitsvorfälle und Messung der Reaktionszeit
    - Analyse der Reaktionszeit, dass in Abteilung A die Reaktionszeit signifikant höher ist.
    - Es wird als passabel gewertet, da diese Vorfälle nur niedrige Priorität hatten.

Norm | Abschnitt 9 |Bewertung der Leistung | 9.1 Überwachung, Messung, Analyse und Bewertung

- **Überwachen und Messen**
  - **Prozentualer Anteil** der **Informationssicherheitskontrollen**, die **implementiert** und wirksam sind
  - **Prozentsatz** der ISMS-Prozesse, die **pünktlich und innerhalb des Budgets** abgeschlossen werden
  - Grad der **Mitarbeiterzufriedenheit** mit dem ISMS
  - **Bewusstsein** für die **Informationssicherheit** und Schulung: Dazu gehört die Überwachung und **Messung** der Wirksamkeit der **Programme zur Sensibilisierung** und Schulung für die Informationssicherheit, um sicherzustellen, dass die Mitarbeitenden mit den Risiken und Richtlinien der Organisation für die Informationssicherheit vertraut sind.
    - Anzahl der Absolvierten Programme
    - Anzahl der Programme pro Mitarbeiter
    - ….

Norm | Abschnitt 9 |Bewertung der Leistung | 9.1 Überwachung, Messung, Analyse und Bewertung

- **KPIs für die ISO**
  - **Anzahl der Vorfälle** im Bereich der Informationssicherheit
  - **Zeit von der Erkennung bis zur Reaktion von** Informationssicherheitsvorfälle
  - **Kosten** von Informationssicherheitsvorfällen
  - **Einhaltung** von **Vorschriften** und Standards zur Informationssicherheit
  - **Prozentualer Anteil** der **Informationssicherheitskontrollen**, die **implementiert** und wirksam sind
  - **Prozentsatz** der ISMS-Prozesse, die **pünktlich und innerhalb des Budgets** abgeschlossen werden
  - Grad der **Mitarbeiterzufriedenheit** mit dem ISMS
  - **Bewusstsein** für die **Informationssicherheit** und Schulung: Dazu gehört die Überwachung und **Messung** der Wirksamkeit der **Programme zur Sensibilisierung** und Schulung für die Informationssicherheit, um sicherzustellen, dass die Mitarbeitenden mit den Risiken und Richtlinien der Organisation für die Informationssicherheit vertraut sind.
    - Anzahl der Absolvierten Programme
    - Anzahl der Programme pro Mitarbeiter
    - ….

Norm | Abschnitt 9 |Bewertung der Leistung | 9.2 Internes Audit

- Organisation muss in geplanten Abständen interne Audits durchführen

- Ziel:
  - Sind die Anforderungen der Norm oder einzelner Ziele erfüllt?
  - Wird das ISMS verwirklicht und aufrecht erhalten?

Norm | Abschnitt 9 |Bewertung der Leistung | 9.2 Internes Audit

- **Was** ist ein internes Audit?
  - Ein internes ISO 27001-Audit ist eine **unabhängige Bewertung des ISMS**, um festzustellen, ob es den **Anforderungen** von ISO 27001 **entspricht und ob es wirksam** funktioniert. Das Audit wird von einem internen Prüfer durchgeführt, der von dem zu prüfenden ISMS unabhängig ist.
- **Warum** ist es wichtig?
  - Die Norm verlangt es
  - Schwachstellen frühzeitig erkennen
  - Verbesserungspotenziale erkennen
  - Gewissheit, dass das ISMS funktioniert

Norm | Abschnitt 9 |Bewertung der Leistung | 9.2 Internes Audit

- **Worauf** wird Wert gelegt?
  - Der sucht **Auditor** nach **Beweisen** dafür, dass das ISMS den **Anforderungen** von ISO 27001 entspricht und effektiv **funktioniert**.
  - **Risikobewertung**: Beurteilung ob eine Risikobewertung gemacht wurde
  - **Kontrollen**: Es wird geprüft, ob IS-Kontrollen eingeführt und aufrecht erhalten bleiben → Risiken mindern
  - **Dokumentation**: Beurteilung, ob die Dokumentation ausreicht
  - **Bewusstsein und Schulungen**: Sind die Mitarbeiter ausreichend mit z.B. Awareness Programmen geschult worden

Norm | Abschnitt 9 |Bewertung der Leistung | 9.2 Internes Audit

- **Ablauf**
  - Prüfen der Dokumente
  - Begehung vor Ort
  - Gespräche mit Mitarbeitern

Norm | Abschnitt 9 |Bewertung der Leistung | 9.2 Internes/Externes Audit – technische Bereiche

- Audits können aber auch für rein technische Bereiche gemacht werden

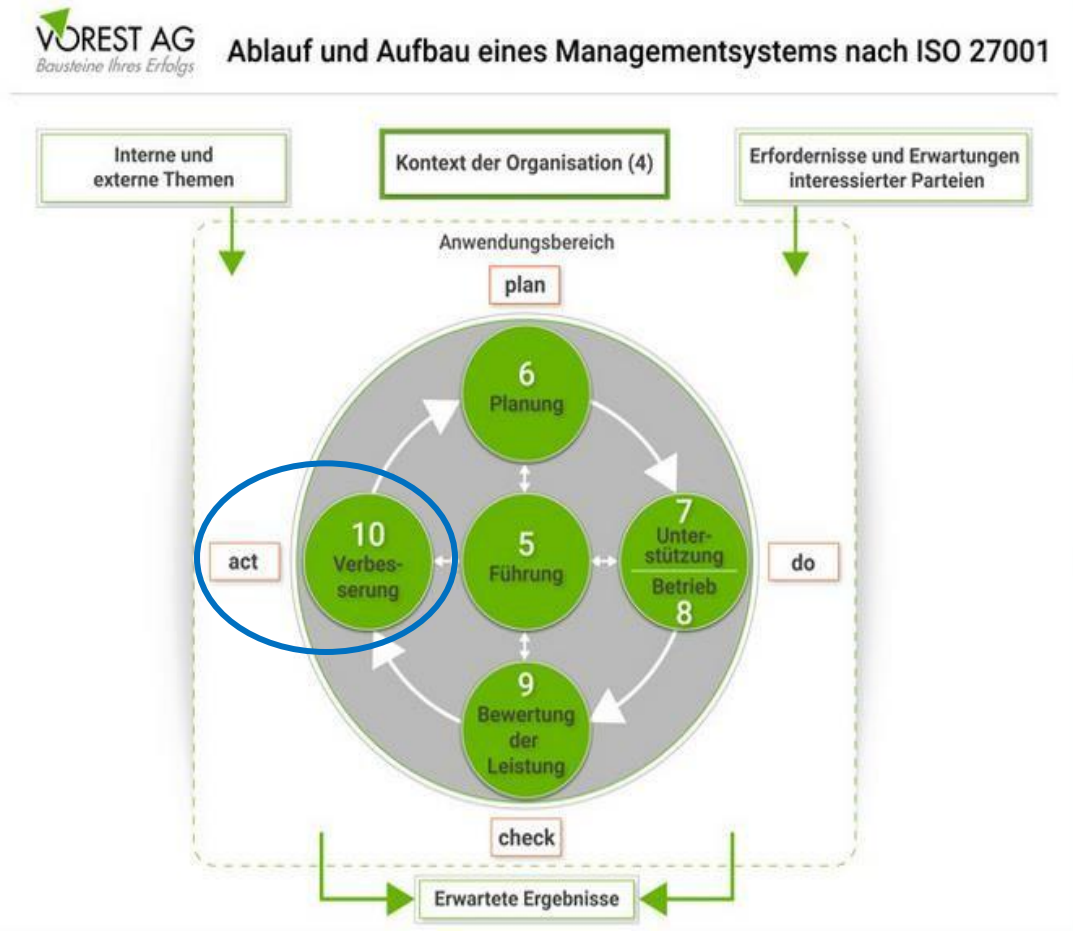
- Bsp:
  Eine Active Directory wurde vor 10 Jahren in Betrieb genommen und seither immer wieder upgedated und gepatched.
  Die Verantwortlichen des Servers änderten sich mehrmals.
  - Ein Audit durchleuchtet den Domain Controller auf die aktuelle Version und ob kritische Konfigurationen vorhanden sind
    - Schwachstelle: https://nvd.nist.gov/vuln/detail/CVE-2020-1472
    - Fix: https://support.microsoft.com/en-us/topic/how-to-manage-the-changes-in-netlogon-secure-channel-connections-associated-with-cve-2020-1472-f7e8cc17-0309-1d6a-304e-5ba73cd1a11e

Norm | Abschnitt 9 |Bewertung der Leistung | 9.3 Managementbewertung

- Das Management muss in regelmäßigen Abständen das ISMS der Organisation neu auf ihre Eignung, Angemessenheit und Wirksamkeit bewerten

- Aufgaben:
  - Hat sich das interne/externe Umfeld verändert
  - Rückmeldungen/Ergebnisse von bereits umgesetzten Maßnahmen
  - Status des Risikobehandlungsplans sichten
  - Möglichkeiten zur fortlaufenden Verbesserung erkennen

Norm | Abschnitt 10 | Verbesserung



1. Anwendungsbereich
2. Normative Verweisungen
3. Begriffe
4. Kontext der Organisation
5. Führung
6. Planung
7. Unterstützung
8. Betrieb
9. Bewertung der Leistung
10. Verbesserung

Norm | Abschnitt 10 | Verbesserung | 10.1 Nichtkonformität und Korrekturmaßnahmen

- Bei Nichtkonformitäten muss die Organisation auf jeden Fall reagieren
  - Dokumentieren des Problems
  - Korrekturmaßnahmen ergreifen → sprich beheben
    - Planen
    - Umsetzen
    - Überwachen
    - Wirksamkeit überprüfen
  - All diese Punkte müssen wieder angemessen dokumentiert werden

- Nichtkonformitäten und deren Korrekturmaßnahmen werden beim nächsten Audit sicher besonders genau betrachtet.

Norm | Abschnitt 10 | Verbesserung | 10.1 Nichtkonformität und Korrekturmaßnahmen

- Was ist eine Nichtkonformität?

  - **Vollständige Nichterfüllung einer bestimmten Anforderung der Norm:** Wenn Ihr Unternehmen eine bestimmte Anforderung überhaupt nicht erfüllt hat. Beispiel: Es wurde keine Maßnahmen zum Umgang mit Risiken ergriffen.

  - **Zusammenbruch eines Prozesses oder Verfahrens:** Wenn Ihr Verfahren völlig aus dem Ruder gelaufen ist - zum Beispiel, wenn Sie einmal am Tag eine Sicherung durchführen mussten, während die Sicherung nur ein paar Mal im Monat oder noch besser zufällig durchgeführt wurde.

  - **Die Anhäufung kleinerer Nichtkonformitäten in Bezug auf einen Prozess oder ein Element Ihres Managementsystems, die auf ein größeres Problem oder das Fehlen der vorgeschriebenen Dokumentation hinweisen:** Wenn mehrere geringfügige Nichtkonformitäten auftreten, die sich auf denselben Prozess oder dasselbe Element Ihres ISMS beziehen. Ein gutes Beispiel ist die Schulung des Sicherheitsbewusstseins der Mitarbeiter: zum Beispiel, wenn keine Zertifikate vorhanden sind.

  - **Geringfügige Nichtkonformitäten, die nicht innerhalb der dafür vorgesehenen Frist behoben werden:** Wurde ein beim letzten Audit festgestellter geringfügiger Fehler nicht innerhalb der Frist behoben, wird dieser geringfügige Fehler automatisch zu einem schwerwiegenden Fehler.

Norm | Abschnitt 10 | Verbesserung | 10.2 Fortlaufende Verbesserung

- Die Organisation muss das ISMS fortlaufend verbessern.

Zusammenfassung

- **ISO 27001: Eine Rahmenstruktur für Informationssicherheit**
  - Definition von Richtlinien und Prozessen
  - Risikomanagement und Kontrollen zur Sicherung von Informationen
- **Vorteile der ISO 27001-Zertifizierung**
  - Verbesserte Datensicherheit und Risikomanagement
  - Erhöhte Glaubwürdigkeit bei Kunden und Partnern
  - Gesetzes- und Vorschriftenkonformität
- **Schritte zur Implementierung von ISO 27001**
  - Analyse von Risiken und Schwachstellen
  - Entwicklung von Sicherheitskontrollen
  - Umsetzung und Überwachung
- **Kontinuierliche Verbesserung und Compliance**
  - Regelmäßige Überprüfung und Aktualisierung der Sicherheitsmaßnahmen
  - Einhaltung von gesetzlichen Anforderungen und Vorschriften

Zusammenfassung

- **Die ISO 27001** bietet eine **robuste Struktur** für die Informationssicherheit, die Organisationen dabei **unterstützt**, **Risiken zu minimieren** und **Vertrauen** bei Kunden und Partnern **aufzubauen**.
- Die Einführung eines ISMS kann am Beginn etwas chaotisch sein – Mit fortlaufender Planungstiefe und gewonnener Routine verbessert sich die Situation aber recht schnell.
- Ein ISMS betrachtet eine Organisation ganzheitlich. → Im Zuge des ISMS **finden** sich
  - manche **Altlasten**, die **bereinigt** werden können.
  - **Bereiche**, die funktionierten, aber **nicht geregelt** und dokumentiert waren. (z.B. eine Person kümmert sich um das Netzwerk)